GRC103 — Risk Assessment and Management Techniques

Week 1 Practical Lab Report

Vulnerability Assessment Report

Student Name: Imelda Sanya

Registration Number:C11/26/CGRCE/17576

1. Executive Summary

I assessed the assigned lab host, 172.16.182.129, using Nmap, Nikto and Nuclei. I then ran targeted checks against PostgreSQL, AJP, Samba and FTP to see what could be confirmed. The scans found several older services, including PostgreSQL on port 5432, AJP on 8009, Samba on 445 with SMBv1 enabled, and vsftpd 2.3.4 on port 21. Nikto also reported web-server issues such as directory browsing, an exposed phpinfo page, HTTP TRACE and missing security headers.

If these services are left exposed, an attacker may have more opportunities to access data, disrupt the host or try to move to other systems. The first steps should be to limit access to services that are not needed, check authentication settings and plan upgrades for unsupported software. Some scanner alerts still need more evidence: I have not confirmed the PostgreSQL empty-password issue, Ghostcat, the specific Samba CVE or the old vsftpd backdoor.

This report reflects the outputs shared during the lab. Risk ratings are preliminary qualitative estimates and the control mapping uses NIST CSF 2.0 as a reference. Neither should be read as proof of regulatory or framework non-compliance.

2. Scope and Approach

Target host: 172.16.182.129

Testing environment: Kali Linux, working directory ~/Lab1-Vulnerability-Assessment

Tools used: Nmap 7.99, Nikto 2.6.0, and Nuclei 3.8.0.

I started with Nmap to identify open ports and services, then used Nikto and Nuclei to check for common web and service weaknesses. I followed up with targeted Nmap checks for PostgreSQL (5432), AJP (8009), Samba/SMB (445), and FTP (21 and 6200). These follow-up scans were used to collect more evidence; I did not attempt to exploit the target.

Limitations: The report is based on the terminal outputs and findings shared in the conversation. The full raw Nmap, Nikto, and Nuclei output files were not provided as attachments for independent review. Where exact evidence was unavailable, findings are described at the level supported by the shared output.

3. Key Findings

F-01: Legacy PostgreSQL service exposed

Affected service	**5432/TCP**
Priority	Review / High priority
Evidence	Nmap identified PostgreSQL DB 8.3.0–8.3.7 listening on port 5432. A Nuclei result reported a PostgreSQL empty-password/default-login concern. The attempted psql connection returned “fe_sendauth: no password supplied”; it did not confirm that an empty password was accepted.

Validation status	PostgreSQL and its version were identified. Empty-password access was not confirmed.
Recommended action	Restrict database access to trusted hosts, review pg_hba.conf and account authentication settings on the target, verify account password policy, and plan migration to a supported PostgreSQL release.

F-02: AJP service exposed; Ghostcat applicability unverified

Affected service	**8009/TCP**
Priority	Review / High priority
Evidence	Nmap identified Apache JServ Protocol (AJP) v1.3. The ajp-headers script returned Content-Type: text/html;charset=ISO-8859-1. The ajp-methods script did not receive a valid response to its OPTION request. These results do not identify the Tomcat version or prove CVE-2020-1938.
Validation status	AJP was identified, but Ghostcat was not confirmed.
Recommended action	Determine the underlying Tomcat version and AJP connector configuration. Disable AJP if unnecessary; otherwise bind it to localhost or restrict it to trusted systems and apply vendor-supported updates.

F-03: Legacy Samba and SMBv1 support

Affected service	**445/TCP**
Priority	Review / High priority
Evidence	Nmap identified Samba 3.0.20-Debian and reported SMBv1 dialect NT LM 0.12. Nuclei also flagged a specific Samba CVE. The service/version/protocol evidence does not by itself confirm that the CVE applies to the installed build and configuration.
Validation status	Samba 3.0.20-Debian and SMBv1 were identified; the specific CVE needs more checking.
Recommended action	Upgrade Samba to a supported release, disable SMBv1 where possible, restrict port 445 to trusted networks, and review the Samba configuration against the relevant vendor advisory.

F-04: Legacy vsftpd service; historical backdoor unverified

Affected service	**21/TCP; 6200/TCP**
Priority	Review / High priority
Evidence	Nmap identified vsftpd 2.3.4 on port 21. Port 6200 was closed during the scan. The version banner does not prove the binary is the historically backdoored distribution associated with CVE-2011-2523; the closed port alone does not conclusively rule it out.
Validation status	FTP service/version confirmed; backdoor unverified.
Recommended action	Verify package provenance and the installed binary on the target, replace unsupported software, restrict FTP access, and prefer a secure transfer service such as SFTP where suitable. Do not trigger the suspected backdoor as a test.

F-05: Web server information exposure and hardening gaps

Affected service	**HTTP / port 80 (reported by Nikto)**
Priority	Medium / Review
Evidence	Nikto reported Apache 2.2.8, PHP 5.2.4, directory indexing at /icons/ and /doc/, an exposed phpinfo.php page, HTTP TRACE, and missing headers including HSTS, X-Content-Type-Options, Content-Security-Policy, Referrer-Policy, and Permissions-Policy.
Validation status	Reported by Nikto; individual items should be checked against the saved raw output and current server configuration.
Recommended action	Upgrade the web server and PHP stack, remove phpinfo.php, disable directory listing where not required, review HTTP TRACE, and configure appropriate security headers.

F-06: Web application and server findings reported by Nuclei

Affected service	**HTTP and multiple service ports**
Priority	Mixed severities; verify individually
Evidence	The shared Nuclei output summary contained 4 Critical, 18 High, 3 Medium, 7 Low, and 40 Info findings. Examples included PHP/CVE-related checks, directory listing, phpinfo, VNC default-login detections, PostgreSQL default-login detections, FTP-related detections, and AJP/Samba findings. Scanner detections are not all independently confirmed.
Validation status	Nuclei reported these issues. Check each one before calling it confirmed.
Recommended action	Review the full nuclei_web_scan.txt, group duplicate findings by root cause, manually validate safely, and record evidence, affected component, confidence, and remediation for each issue.

4. Validation Evidence Collected

- postgres_validation.txt — confirmed port 5432 open; PostgreSQL DB 8.3.0–8.3.7 detected.
- ajp_validation.txt — confirmed port 8009 open; Apache JServ Protocol v1.3 detected.
- ajp_details.txt — recorded AJP header response and a non-valid response to the OPTION request.
- samba_validation.txt — confirmed port 445 open, Samba 3.0.20-Debian, and SMBv1 support.
- ftp_validation.txt — confirmed vsftpd 2.3.4 on port 21; port 6200 was closed at scan time.
- nikto_scan.txt.txt — reported web server/version and web hardening issues, according to the output shared.
- nuclei_web_scan.txt — Nuclei findings summary: 4 Critical, 18 High, 3 Medium, 7 Low, 40 Info.
- initial_scan.xml and related Nmap output — initial discovery/service scan evidence was referenced during the assessment.

5. Recommended Remediation Order

1. Limit network access to services that are not required, especially database, SMB, AJP, FTP, and VNC ports.

2. Verify authentication configuration for PostgreSQL and any VNC or other default-credential detections. Do not treat scanner output alone as proof of successful login.
3. Confirm software versions and configuration for CVE-specific findings before marking them confirmed.
4. Upgrade unsupported services and runtimes, prioritising internet- or broadly reachable components.
5. Remove exposed diagnostic pages, disable unnecessary directory listings and legacy protocols, and configure appropriate web security headers.
6. Re-run the relevant scans after remediation and compare the results with the saved baseline evidence.

6. Overall Conclusion

The scans identified multiple areas that need attention, especially legacy services and unnecessary service exposure. The strongest confirmed results are the exposed service ports, the reported legacy service versions, SMBv1 support, and the web-server issues reported by Nikto. Several critical CVE and default-credential detections remain unverified because the follow-up checks did not establish the conditions required to confirm them. The next step is to review the full raw scanner output and, where authorised, verify each remaining finding through configuration review or a controlled test. After changes are made, repeat the scans to confirm that the risks have been reduced.

Appendix A: Evidence File Names

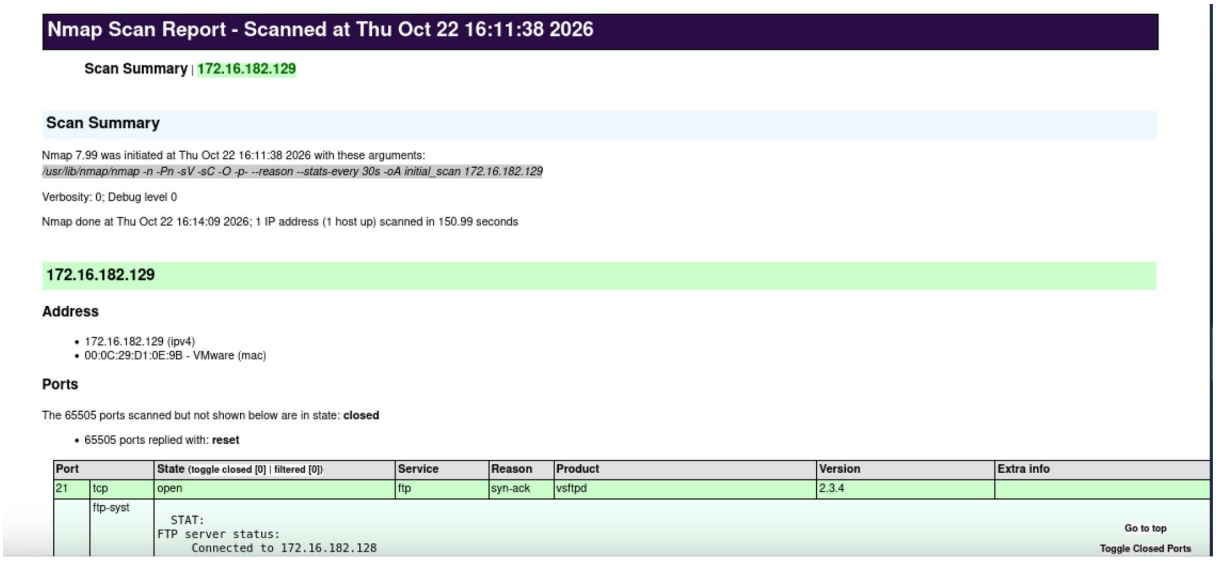
The following files were reported as present in the lab working directory: postgres_validation.txt, ajp_validation.txt, ajp_details.txt, samba_validation.txt, ftp_validation.txt, and combined_validation_evidence.txt. The report also references nikto_scan.txt.txt, nuclei_web_scan.txt, and initial Nmap scan outputs.

Note: Severity labels in this report are intentionally cautious where the exact original scanner severity and full finding evidence were not available in the shared excerpts. Use the original Nuclei/Nikto output when finalising each finding's severity.

Appendix B: Screenshot Evidence

The screenshots below provide visual evidence of the main scan stages and selected findings. They supplement the raw text output files listed in the report. Captions describe the evidence shown and do not imply that every scanner finding has been independently confirmed.

Nmap report overview for the target host.



Nmap Scan Report - Scanned at Thu Oct 22 16:11:38 2026

Scan Summary | 172.16.182.129

Scan Summary

Nmap 7.99 was initiated at Thu Oct 22 16:11:38 2026 with these arguments:
/usr/lib/nmap/nmap -n -Pn -sV -sC -O -p- --reason --stats-every 30s -oA initial_scan 172.16.182.129

Verbosity: 0; Debug level 0

Nmap done at Thu Oct 22 16:14:09 2026; 1 IP address (1 host up) scanned in 150.99 seconds

172.16.182.129

Address

- 172.16.182.129 (ipv4)
- 00:0C:29:D1:0E:9B - VMware (mac)

Ports

The 65505 ports scanned but not shown below are in state: **closed**

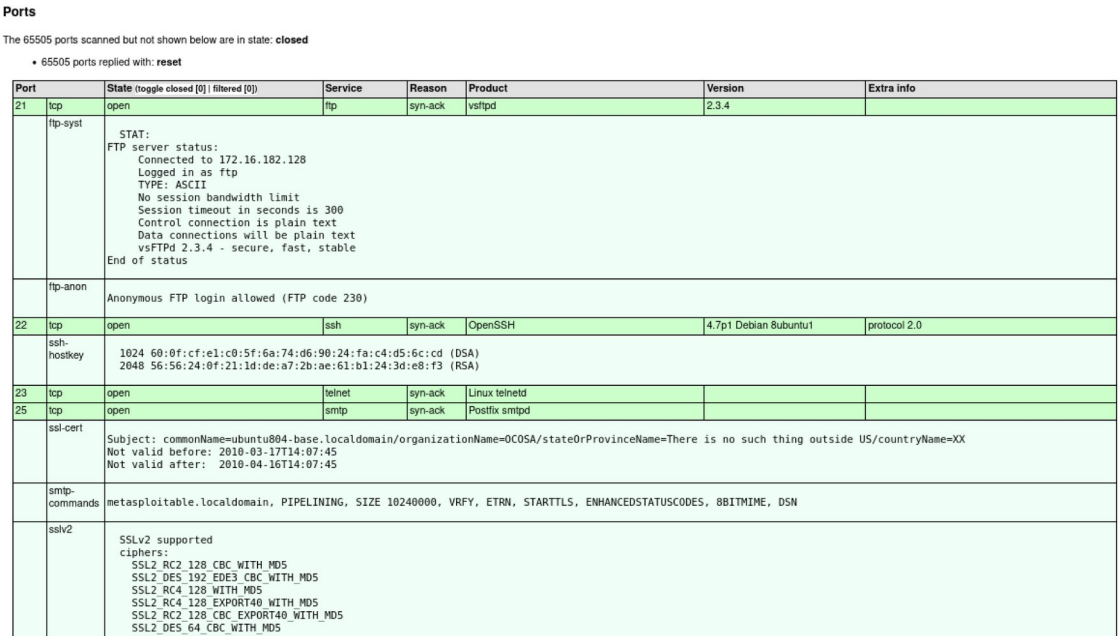
- 65505 ports replied with: **reset**

Port		State (toggle closed [0] | filtered [0])	Service	Reason	Product	Version	Extra info
21	tcp	open	ftp	syn-ack	vsftpd	2.3.4	
	ftp-syst	STAT: FTP server status: Connected to 172.16.182.128					

Go to top
Toggle Closed Ports

Figure A1. Nmap report overview for the target host.

Open ports identified during the Nmap scan.



Ports

The 65505 ports scanned but not shown below are in state: **closed**

- 65505 ports replied with: **reset**

Port		State (toggle closed [0] | filtered [0])	Service	Reason	Product	Version	Extra info
21	tcp	open	ftp	syn-ack	vsftpd	2.3.4	
	ftp-syst	STAT: FTP server status: Connected to 172.16.182.128 Logged in as ftp TYPE: ASCII No session bandwidth limit Session timeout in seconds is 300 Control connection is plain text Data connections will be plain text vsFTPd 2.3.4 - secure, fast, stable End of status					
	ftp-anon	Anonymous FTP login allowed (FTP code 230)					
22	tcp	open	ssh	syn-ack	OpenSSH	4.7p1 Debian 8ubuntu1	protocol 2.0
	ssh-hostkey	1024 60:0f:cf:e1:c0:5f:6a:74:d6:90:24:fa:c4:d5:6c:cd (DSA) 2048 56:56:24:0f:21:1d:de:a7:2b:ae:61:b1:24:3d:e8:f3 (RSA)					
23	tcp	open	telnet	syn-ack	Linux telnetd		
25	tcp	open	smtp	syn-ack	Postfix smtpd		
	ssl-cert	Subject: commonName=ubuntu804-base.localdomain/organizationName=OCOSA/stateOrProvinceName=There is no such thing outside US/countryName=XX Not valid before: 2010-03-17T14:07:45 Not valid after: 2010-04-16T14:07:45					
	smtp-commands	metasploitable.localdomain, PIPELINING, SIZE 10240000, VRFY, ETRN, STARTTLS, ENHANCEDSTATUSCODES, 8BITMIME, DSN					
	sslv2	SSLv2 supported ciphers: SSL2_RC2_128_CBC_WITH_MD5 SSL2_DES_192_EDE3_CBC_WITH_MD5 SSL2_RC4_128_WITH_MD5 SSL2_RC4_128_EXPORT40_WITH_MD5 SSL2_RC2_128_CBC_EXPORT40_WITH_MD5 SSL2_DES_64_CBC_WITH_MD5					

Figure A2. Open ports identified during the Nmap scan.

Additional service and host findings from Nmap.

Remote Operating System Detection

- Used port: **21/tcp** (**open**)
- Used port: **1/tcp** (**closed**)
- Used port: **38054/udp** (**closed**)
- OS match: **Linux 2.6.9 - 2.6.33** (**100%**)

Host Script Output

Script Name	Output
clock-skew	mean: 1h00m08s, deviation: 2h00m00s, median: 7s
smb-os-discovery	OS: Unix (Samba 3.0.20-Debian) Computer name: metasploitable NetBIOS computer name: Domain name: localdomain FQDN: metasploitable.localdomain System time: 2026-10-22T09:14:08-04:00
smb-security-mode	account_used: <blank> authentication_level: user challenge_response: supported message_signing: disabled (dangerous, but default)
nbstat	NetBIOS name: METASPLOITABLE, NetBIOS user: <unknown>, NetBIOS MAC: <unknown> (unknown)
smb2-time	Protocol negotiation failed (SMB2)

Figure A3. Additional service and host findings from Nmap.

Summary of Nuclei findings by severity.

```
┌──(nabs㉿kali-cyber-lab)-[~]
└─$ cd ~/Lab1-Vulnerability-Assessment

grep -c '\[critical\]' nuclei_web_scan.txt
grep -c '\[high\]' nuclei_web_scan.txt
grep -c '\[medium\]' nuclei_web_scan.txt
grep -c '\[low\]' nuclei_web_scan.txt
grep -c '\[info\]' nuclei_web_scan.txt
4
18
3
7
40

┌──(nabs㉿kali-cyber-lab)-[~/Lab1-Vulnerability-Assessment]
└─$
```

Figure A4. Summary of Nuclei findings by severity.

Nikto web-server findings.

```
┌──(nabs㉿kali-cyber-lab)-[~]
└─$ cat ~/Lab1-Vulnerability-Assessment/nuclei_web_scan.txt

┌──(nabs㉿kali-cyber-lab)-[~]
└─$ head -n 20 ~/Lab1-Vulnerability-Assessment/nikto_scan.txt
- Nikto v2.6.0/
+ Target Host: 172.16.182.129
+ Target Port: 80
+ GET /: Retrieved x-powered-by header: PHP/5.2.4-2ubuntu5.10.
+ GET /icons/: Directory indexing found.
+ GET /index: Uncommon header(s) 'tcn' found, with contents: list.
+ GET /index: Apache mod_negotiation is enabled with MultiViews, which allows attackers to easily b
rute force file names. The following alternatives for 'index' were found: index.php. See: http://ww
w.wisec.it/sectou.php?id=4698ebdc59d15,https://exchange.xforce.ibmcloud.com/vulnerabilities/8275:
+ GET /: Suggested security header missing: referrer-policy. See: https://developer.mozilla.org/en-
US/docs/Web/HTTP/Headers/Referrer-Policy:
+ GET /: Suggested security header missing: permissions-policy. See: https://developer.mozilla.org/
en-US/docs/Web/HTTP/Headers/Permissions-Policy:
+ GET /: Suggested security header missing: strict-transport-security. See: https://developer.mozil
la.org/en-US/docs/Web/HTTP/Headers/Strict-Transport-Security:
+ GET /: Suggested security header missing: x-content-type-options. See: https://developer.mozilla.
org/en-US/docs/Web/HTTP/Headers/X-Content-Type-Options:
+ GET /: Suggested security header missing: content-security-policy. See: https://developer.mozilla
.org/en-US/docs/Web/HTTP/CSP:
+ HEAD Apache/2.2.8 appears to be outdated (current is at least 2.4.66).
+ HEAD PHP/5.2.4-2ubuntu5.10 appears to be outdated (current is at least 8.5.1).
+ NUUUPIDO /: Web Server returns a valid response with junk HTTP methods which may cause false posi
tives.
+ TRACE /: HTTP TRACE method is active and replies which suggests the host is vulnerable to XST. Se
e: https://owasp.org/www-community/attacks/Cross_Site_Tracing:
+ GET /phpinfo.php: Output from the phpinfo() function was found.
+ GET /doc/: Directory indexing found.
+ GET /doc/: The /doc/ directory is browsable. This may be /usr/doc. See: CVE-1999-0678:
+ GET /?=PHPB8B5F2A0-3C92-11d3-A3A9-4C7B08C10000: PHP Easter Eggs reveals potentially sensitive inf
ormation via HTTP requests that contain specific QUERY strings. See: https://labs.detectify.com/wri
teups/do-you-dare-to-show-your-php-easter-egg/:
```

Figure A5. Nikto web-server findings.

Targeted service-validation evidence.

```
┌──(nabs㉿kali-cyber-lab)-[~/Lab1-Vulnerability-Assessment]
└─$ cat validation_scan.txt
# Nmap 7.99 scan initiated Thu Oct 22 18:11:35 2026 as: /usr/lib/nmap/nmap --privileged -sV -p 21,4
45,5432,8009,6200,3632,5900 -oN validation_scan.txt 172.16.182.129
Nmap scan report for 172.16.182.129
Host is up (0.0028s latency).

PORT     STATE  SERVICE     VERSION
21/tcp   open   ftp         vsftpd 2.3.4
445/tcp  open   netbios-ssn Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
3632/tcp open   distccd     distccd v1 ((GNU) 4.2.4 (Ubuntu 4.2.4-1ubuntu4))
5432/tcp open   postgresql  PostgreSQL DB 8.3.0 - 8.3.7
5900/tcp open   vnc         VNC (protocol 3.3)
6200/tcp closed lm-x
8009/tcp open   ajp13       Apache Jserv (Protocol v1.3)
Service Info: OS: Unix

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
# Nmap done at Thu Oct 22 18:11:51 2026 -- 1 IP address (1 host up) scanned in 16.07 seconds
```

Figure A6. Targeted service-validation evidence.

Nuclei web-scan results.

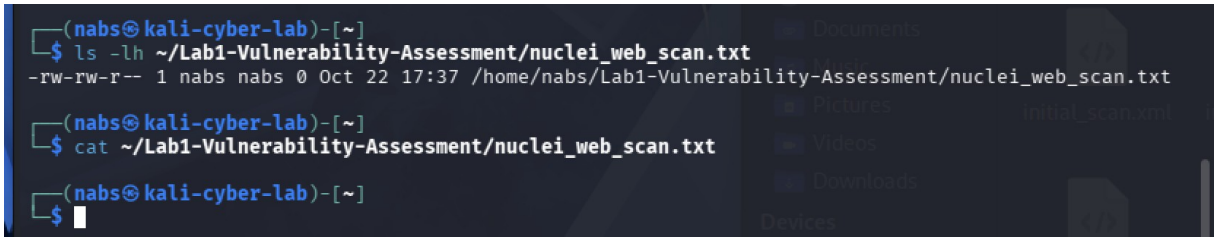


Figure A7. Nuclei web-scan results.

7. Inherent Risk Assessment

These are preliminary qualitative inherent-risk estimates before remediation or compensating controls. Likelihood and impact are judgements based on the observed exposure and potential consequence, not measured probabilities. Ratings should be updated if further validation changes the evidence.

Finding	Likelihood	Impact	Inherent risk	Business significance	Evidence confidence
PostgreSQL exposed; empty-password finding unverified	Possible	Major	High	Weak authentication could expose or alter database data.	Service/version confirmed; empty password unverified
AJP exposed; Ghostcat unverified	Possible	Major	High	If a vulnerable Tomcat version/configuration is present, application resources may be exposed.	AJP confirmed; CVE unverified
Legacy Samba and SMBv1; specific CVE unverified	Likely	Major	High	Legacy file sharing may expose data and increase lateral-movement risk.	Version and SMBv1 confirmed; CVE unverified
vsftpd 2.3.4; backdoor unverified	Possible	Major	High	A vulnerable or backdoored FTP service could permit unauthorised host access.	Version confirmed; backdoor unverified
Legacy web stack and hardening gaps	Likely	Moderate to Major	High	Outdated components, diagnostic pages and directory listings increase exposure.	Nikto-reported; verify individual items
Other Nuclei detections, including default-login findings	Possible	Moderate to Major	Medium–High	If valid, weak credentials or vulnerable services could expose interfaces or data.	Scanner-reported; validate individually

Scale used: Likelihood—Unlikely/Possible/Likely; Impact—Minor/Moderate/Major/Severe; Inherent risk—Low/Medium/High/Critical. These ratings help prioritise work and do not mean that an unverified vulnerability has been proven exploitable.

8. Security Control Mapping

Framework selected: NIST Cybersecurity Framework (CSF) 2.0 (2024). The references below are a practical cross-reference to relevant outcomes. This mapping does not, on its own, establish compliance or non-compliance; that requires the organisation's applicable requirements and supporting evidence.

Finding area	NIST CSF 2.0 reference	Relevance	Suggested action
Asset and service inventory	ID.AM-01; ID.AM-02	Maintain inventories of assets and software/services.	Record exposed services, owners, business purpose and approved ports.
Vulnerability and software lifecycle	ID.RA-01; ID.RA-08; PR.PS-02	Identify vulnerabilities, assess risk and manage software securely.	Verify affected builds, prioritise upgrades and track remediation.
Database and service access	PR.AA-05; PR.IR-01	Access control and network architecture reduce unauthorised access.	Review authentication and restrict ports to approved hosts.
AJP, SMBv1 and FTP exposure	PR.IR-01; PR.PS-01	Secure architecture and configuration reduce unnecessary exposure.	Disable unnecessary services/protocols and limit access to trusted systems.
Web hardening and information exposure	PR.PS-01; PR.PS-02	Secure configurations and vulnerability management reduce avoidable exposure.	Remove diagnostic pages, disable unnecessary directory listing, configure headers and upgrade unsupported components.
Validation and ongoing improvement	ID.RA-01; ID.RA-06; ID.IM-01	Risk assessment and continuous improvement support risk management.	Record evidence and confidence; re-scan after remediation.

Framework note: CSF categories and subcategories are outcome statements, not pass/fail tests. Use these references to guide review and remediation; do not call a finding a compliance violation without a defined requirement and evidence.

9. Management Priorities

1. Restrict access to services that are not required, especially database, SMB, AJP, FTP and VNC ports.
2. Review authentication settings and validate default-credential detections through approved, controlled checks.
3. Confirm the software builds and configurations behind CVE detections before marking them as confirmed.

4. Plan upgrades or replacement of unsupported services and runtimes, prioritising broadly reachable components.
5. Remove diagnostic pages, disable unnecessary directory listing and legacy protocols, and improve web-server configuration.
6. Assign an owner and due date to each confirmed issue, then re-scan and record residual risk.